

FECAP - FUNDAÇÃO ESCOLA DE COMÉRCIO ÁLVARES PENTEADO

Curso de Ciência da Computação
6º Semestre - Turma 6º CCOMP

SMASH

PLANO DE GERENCIAMENTO DE RISCOS

Entrega 1 - Redes de Computadores e Cibersegurança

Projeto 7 - Grupo Smash

Felipe Vallim Soares - 24026060
Guilhermy Mariano Lisboa Garcia - 23025371
Gustavo Oliveira Demetrio - 24026213
Saulo Pereira de Jesus - 24026095

Prof. Victor Bruno Alexander Rosetti

São Paulo
2026

IDENTIFICAÇÃO DO DOCUMENTO

Quadro 1 - Identificação do plano.

Campo	Informação
Projeto	Smash - parede instrumentada de treino de tênis (Projeto 7)
Disciplina	Redes de Computadores e Cibersegurança - Entrega 1
Data	25/09/2026
Versão	1.0
Repositório	https://github.com/2026-2-NCC6/Projeto7
Código de referência	Commit 1a99fd6d2bd2312928ef4f3add32b903e67b3452 , pasta src/Entrega1

1 INTRODUÇÃO

Este documento descreve como o gerenciamento de riscos será estruturado e realizado para o projeto Smash. O Smash transforma uma parede comum em uma superfície de treino de tênis com nove alvos em matriz 3×3 , cada um com uma pastilha piezoelétrica lida por um ESP32. O ESP32 identifica o alvo atingido e envia o evento ao aplicativo React Native por WebSocket; o aplicativo conduz os modos de jogo e registra o resultado da sessão na API NestJS, que mantém contas, progressão e histórico no PostgreSQL.

O objetivo é identificar, analisar, planejar respostas e monitorar os riscos para aumentar a probabilidade de sucesso do projeto e minimizar o impacto de eventos negativos. Como o plano é entregue na disciplina de Redes de Computadores e Cibersegurança, ele dá prioridade aos riscos que afetam confidencialidade, integridade e disponibilidade: comunicação entre componentes, autenticação, credenciais e confiança nos dados que chegam de cada camada. Riscos gerenciais, organizacionais e externos também são registrados quando podem impedir que as respostas de segurança sejam implementadas ou demonstradas.

Os riscos técnicos foram levantados sobre o código do projeto no estado indicado no Quadro 1. Cada um aponta o arquivo e a linha em que a condição pode ser conferida (Quadro 9, no Anexo A). Os caminhos citados são relativos à pasta [src/Entrega1](#) do repositório.

2 METODOLOGIA

A abordagem para o gerenciamento de riscos neste projeto será a seguinte:

- **Identificação de Riscos:** os riscos são identificados por revisão estática do código-fonte do firmware, do aplicativo e da API; leitura dos requisitos do documento do Projeto Interdisciplinar; verificação automatizada das dependências com npm

audit; e discussão da equipe nas reuniões de acompanhamento. A revisão foi estática: não foram realizados ataques em rede real nem testes destrutivos no ESP32.

- **Análise de Riscos:** cada risco recebe um nível de probabilidade e um de impacto, conforme as definições da seção 6, e a severidade resulta da matriz da seção 7. A análise é qualitativa. A análise quantitativa não é aplicada porque o projeto não tem orçamento relevante em jogo; o custo real de um risco materializado é tempo de desenvolvimento e exposição de dados.
- **Planejamento de Respostas:** para cada risco de severidade Médio ou superior é definida uma estratégia (prevenir, transferir, mitigar ou aceitar), uma ação concreta, um responsável e um prazo. Riscos Baixos e Muito Baixos podem ser aceitos com monitoramento.
- **Monitoramento e Controle:** o Registro de Riscos é revisado nas reuniões de acompanhamento e atualizado sempre que um risco muda de probabilidade, impacto, responsável ou status. A eficácia de uma resposta é avaliada por evidência verificável no repositório, como commit, configuração ou teste, e não pela intenção declarada.

3 PAPÉIS E RESPONSABILIDADES

Os papéis seguem o modelo de gerenciamento de riscos. A equipe do projeto é dividida pelas trilhas técnicas do Smash, e cada trilha responde pelos riscos da camada que desenvolve. No Registro de Riscos (Anexo A), a coluna Responsável indica a trilha, e o Quadro 2 indica o integrante responsável por ela.

Quadro 2 - Papéis e responsabilidades no gerenciamento de riscos.

Papel	Responsabilidades no Gerenciamento de Riscos
Gerente de Projeto Saulo Pereira de Jesus	Liderar o processo de gerenciamento de riscos e garantir que o plano seja seguido. Manter o Registro de Riscos atualizado no repositório, conduzir a revisão de riscos nas reuniões e comunicar o status ao professor da disciplina.
Equipe do Projeto - Firmware (ESP32) Felipe Vallim Soares	Responder pelos riscos do dispositivo: rede SoftAP, WebSocket, sessão da parede, limites de conexão e calibração dos alvos (R02, R03, R05, R07, R13, R14, R18 e R19).
Equipe do Projeto - Backend (API e banco) Guilhermy Mariano Lisboa Garcia	Responder pelos riscos da API e do PostgreSQL: HTTPS, CORS, limitação de tentativas, credenciais, JWT, validação da sessão, dependências e logs (R01, R04, R06, R08 a R13 e R17).
Equipe do Projeto - Aplicativo Mobile Gustavo Oliveira Demetrio	Responder pelos riscos do cliente: endereço da API, conexão com a parede, dados de sessão enviados ao backend e contas usadas em demonstrações (R01, R02, R11 e R17).
Patrocinador do Projeto	Professor da disciplina, Prof. Victor Bruno Alexander Rosetti. Fornecer orientação e validar os critérios de avaliação. Decidir sobre riscos que excedam a autoridade da equipe, como mudanças de escopo ou de formato de entrega.

Papel	Responsabilidades no Gerenciamento de Riscos
Partes Interessadas	Demais professores do Projeto Interdisciplinar e usuários de teste. Fornecer informações para a identificação de riscos e estar cientes dos principais riscos do projeto.

4 ORÇAMENTO E CRONOGRAMA PARA GERENCIAMENTO DE RISCOS

- **Orçamento:** o projeto é acadêmico, custeado pela equipe e sem verba institucional. O hardware do protótipo custou R\$ 199,39, somando ESP32, pastilhas piezoelétricas, multiplexadores, cabo de rede, diodos, resistores e jumpers; protoboard e placas de MDF já estavam disponíveis. As respostas aos riscos de segurança usam apenas configuração e software livre, sem custo adicional. A reserva de contingência proposta é física: uma segunda placa ESP32 (R\$ 39,99, cerca de 20% do custo de hardware), somada às sobras dos kits de resistores e diodos e à pastilha piezoelétrica excedente do kit de dez unidades.
- **Cronograma:**
 - **Identificação Inicial de Riscos:** 12/09/2026 a 25/09/2026, da revisão estática e do npm audit até o fechamento da Entrega 1.
 - **Reuniões de Acompanhamento de Riscos:** semanais, como item fixo da reunião da equipe, e antes de qualquer demonstração da parede.
 - **Revisões do Plano de Gerenciamento de Riscos:** em cada marco do projeto: Entrega 2, em 06/11/2026, e Apresentação na Semana FECAP de Tecnologia, de 17 a 24/11/2026.

5 CATEGORIAS DE RISCOS

Os riscos serão categorizados da seguinte forma para facilitar a identificação e análise:

- **Técnicos:** relacionados à tecnologia, requisitos, complexidade, interface, desempenho e qualidade. No Smash, abrangem comunicação HTTP e WebSocket, autenticação, credenciais, validação de dados, dependências, firmware do ESP32 e detecção física dos impactos (R01 a R14).
- **Gerenciais:** relacionados ao planejamento, comunicação, recursos e controle. No Smash, o tempo disponível para implementar as respostas até a Entrega 2, em paralelo às demais disciplinas do Projeto Interdisciplinar (R15).
- **Organizacionais:** relacionados às políticas da instituição, critérios de avaliação e dependências entre entregas. No Smash, a alteração de critérios, datas ou formatos de entrega e o tratamento de dados pessoais conforme a LGPD (R16 e R17).

- **Externos:** relacionados a fornecedores, ambiente e fatores fora do controle da equipe. No Smash, a falha da única placa ESP32 disponível e a rede do local de demonstração (R18 e R19).

6 DEFINIÇÕES DE PROBABILIDADE E IMPACTO

As escalas seguem os cinco níveis do modelo. Como o Smash não possui orçamento relevante, o impacto não é medido em aumento de custo, e sim no efeito sobre a segurança do sistema e sobre as entregas. A coluna "Critério no Smash" traduz cada nível para a forma como um risco pode ser explorado ou se materializar neste projeto.

Quadro 3 - Definições de probabilidade.

Nível	Descrição	Critério no Smash	Valor
Muito Alta	Quase certo de ocorrer	A condição está presente e pode ser explorada sem preparo por qualquer pessoa próxima, ou a informação necessária já é pública.	> 80%
Alta	Provável de ocorrer	Pode ser explorada com passos simples por alguém na mesma rede ou com um cliente modificado.	61% - 80%
Média	Pode ocorrer	Exige a mesma rede e alguma preparação, ou depende de uma condição de uso ainda não confirmada.	41% - 60%
Baixa	Improvável de ocorrer	Exige acesso físico, conhecimento específico ou uma combinação pouco provável de fatores.	21% - 40%
Muito Baixa	Muito improvável de ocorrer	Improvável no contexto acadêmico e de demonstração atual.	< 20%

Quadro 4 - Definições de impacto.

Nível	Efeito na segurança do sistema	Efeito nas entregas
Muito Alto	Expõe credenciais, tokens ou dados de todos os usuários, ou permite alterar em larga escala os dados persistidos.	Inviabiliza a demonstração ou um entregável obrigatório.
Alto	Compromete a integridade de progressão, histórico ou eventos, expõe dados de um usuário ou derruba a parede ou a API durante o treino.	Atrasa uma entrega em mais de uma semana ou degrada um requisito obrigatório.
Médio	Interrompe uma sessão, altera dados limitados ou amplia a superfície de ataque sem exposição direta.	Atrasa de três a sete dias ou exige corte de escopo secundário.
Baixo	Afeta uma função limitada, com recuperação simples.	Atraso de até dois dias, absorvido pelo cronograma.
Muito Baixo	Sem efeito perceptível na segurança.	Sem efeito no cronograma ou nos entregáveis.

7 MATRIZ DE PROBABILIDADE E IMPACTO

Esta matriz será utilizada para priorizar os riscos. Cada célula mostra a severidade definida pelo modelo para o cruzamento de probabilidade e impacto e, abaixo dela, os riscos do Registro (Anexo A) que se enquadram naquela combinação.

Quadro 5 - Matriz de probabilidade e impacto com os riscos do Smash.

Probabilidade \ Impacto	Muito Baixo	Baixo	Médio	Alto	Muito Alto
Muito Alta	Médio	Alto	Alto	Extremo R02, R03	Extremo
Alta	Baixo	Médio	Alto R05, R06	Alto R04, R15	Extremo R01
Média	Baixo	Médio	Médio R08, R10, R12, R16, R19	Alto R07, R11, R13, R14, R17	Alto R09
Baixa	Muito Baixo	Baixo	Baixo	Médio R18	Médio
Muito Baixa	Muito Baixo	Muito Baixo	Baixo	Baixo	Médio

- **Extremo/Alto:** requerem atenção imediata e um plano de resposta detalhado. São 13 dos 19 riscos: R01, R02 e R03 em Extremo e 10 em Alto.
- **Médio:** devem ser monitorados de perto. São 6 riscos: R08, R10, R12, R16, R18 e R19.
- **Baixo/Muito Baixo:** serão monitorados como parte das atividades de rotina do projeto. Nenhum risco do registro atual se enquadra nesses níveis.

8 TOLERÂNCIA AO RISCO DAS PARTES INTERESSADAS

A tolerância ao risco no Smash não é uniforme. Ela acompanha os requisitos não funcionais do Projeto Interdisciplinar, que exigem autenticação segura, comunicação cifrada, identificação do dispositivo, proteção contra o OWASP Top 10, minimização de dados e proteção reforçada de menores.

- **Baixa tolerância:** exposição de credenciais, tokens e dados pessoais; alteração indevida de progressão, histórico ou eventos de impacto; e acesso não autorizado à parede durante o treino. Riscos nessa faixa não podem ser aceitos sem resposta.
- **Tolerância moderada:** indisponibilidade temporária da parede ou da API em ambiente de laboratório, desde que a falha seja percebida e a sessão não registre dados incorretos.
- **Alta tolerância:** adiamento de funcionalidades ainda não implementadas, como a integração MQTT e o dashboard web, desde que os controles de segurança sejam definidos antes da implementação.

- **Consequência prática:** diante de conflito entre prazo e escopo, a equipe corta funcionalidades secundárias e preserva as respostas aos riscos Extremos e aos riscos da faixa de baixa tolerância.

9 FORMATOS DE RELATÓRIOS

- **Registro de Riscos:** mantido no Anexo A deste documento e versionado no repositório, na pasta *documentos/*, junto com o código. Cada risco registra identificador, descrição, categoria, probabilidade, impacto, severidade, estratégia, ação, responsável, prazo e status.
- **Relatório de Status dos Riscos:** incluído nos relatórios de cada entrega, apresentando os riscos Extremos e Altos, o status de suas respostas, os riscos materializados e os novos riscos identificados.
- **Evidências:** cada resposta concluída é associada ao commit que a implementa, e a verificação de dependências com npm audit é repetida e registrada a cada entrega.

10 ACOMPANHAMENTO

O processo de gerenciamento de riscos será revisado em cada marco importante do projeto para garantir sua eficácia e para incorporar as lições aprendidas. O Registro de Riscos será um documento vivo e será atualizado continuamente.

Na próxima revisão, as respostas aos riscos Extremos (R01, R02 e R03) devem estar implementadas no código e verificadas, em linha com a Entrega 2 da disciplina, que trata da mitigação aplicada ao sistema.

APROVAÇÃO

Quadro 6 - Aprovação do plano.

Nome	Cargo	Assinatura	Data
Saulo Pereira de Jesus	Gerente do Projeto	Saulo Pereira de Jesus	25/09/2026
Felipe Vallim Soares	Responsável - Firmware (ESP32)	Felipe Vallim Soares	25/09/2026
Guilhermy Mariano Lisboa Garcia	Responsável - Backend (API e banco)	Guilhermy Mariano Lisboa Garcia	25/09/2026
Gustavo Oliveira Demetrio	Responsável - Aplicativo Mobile	Gustavo Oliveira Demetrio	25/09/2026
Prof. Victor Bruno Alexander Rosetti	Patrocinador do Projeto		

ANEXO A - REGISTRO DE RISCOS

O registro abaixo consolida os riscos identificados no Smash. O Quadro 7 mostra a classificação de cada risco, o Quadro 8 a resposta planejada e o Quadro 9 onde cada risco técnico pode ser conferido no código.

Quadro 7 - Registro de riscos.

ID	Risco	Categoria	Prob.	Impacto	Severidade
R01	A API usa HTTP sem criptografia e o aplicativo envia o token JWT nesse canal.	Técnico	Alta	Muito Alto	Extremo
R02	O WebSocket da parede usa ws:// e aceita qualquer cliente sem autenticação.	Técnico	Muito Alta	Alto	Extremo
R03	A senha do SoftAP é previsível e está versionada em repositório público.	Técnico	Muito Alta	Alto	Extremo
R04	O resultado da sessão é declarado pelo aplicativo e aceito pelo backend sem prova de que a partida ocorreu.	Técnico	Alta	Alto	Alto
R05	Qualquer cliente conectado pode trocar o identificador global de sessão da parede.	Técnico	Alta	Médio	Alto
R06	Login e cadastro não têm limitação de tentativas.	Técnico	Alta	Médio	Alto
R07	O ESP32 não limita clientes, tamanho de mensagens ou frequência de comandos.	Técnico	Média	Alto	Alto
R08	A API aceita qualquer origem CORS e escuta em todas as interfaces.	Técnico	Média	Médio	Médio
R09	O banco usa usuário e senha padrão de desenvolvimento como fallback.	Técnico	Média	Muito Alto	Alto
R10	O JWT dura sete dias e não possui revogação no servidor.	Técnico	Média	Médio	Médio
R11	As dependências possuem alertas conhecidos no npm audit.	Técnico	Média	Alto	Alto
R12	Eventos de segurança têm pouca trilha de auditoria.	Técnico	Média	Médio	Médio
R13	A integração MQTT prevista ainda não tem controles de segurança definidos.	Técnico	Média	Alto	Alto
R14	Isolamento mecânico insuficiente entre as placas faz a parede registrar o alvo errado.	Técnico	Média	Alto	Alto
R15	Tempo insuficiente para implementar as respostas até a Entrega 2, em paralelo às demais disciplinas.	Gerencial	Alta	Alto	Alto
R16	Alteração de critérios, datas ou formatos das entregas pelos docentes.	Organizacional	Média	Médio	Médio
R17	Dados pessoais reais usados em testes e demonstrações, em desacordo com a LGPD.	Organizacional	Média	Alto	Alto
R18	Falha ou dano da única placa ESP32 disponível.	Externo	Baixa	Alto	Médio
R19	Rede Wi-Fi do local de demonstração indisponível ou instável.	Externo	Média	Médio	Médio

Quadro 8 - Plano de respostas aos riscos.

ID	Estratégia	Ações planejadas	Responsável	Prazo	Status
R01	Mitigar	Publicar a API atrás de proxy HTTPS com certificado confiável, mudar o endereço padrão do aplicativo para https e não expor a porta 3000 fora da rede de testes.	Backend e Aplicativo	Entrega 2	Não iniciado
R02	Mitigar	Isolar a rede da parede nas demonstrações, autenticar o aplicativo no início da conexão com segredo de pareamento e adotar WSS ou gateway seguro fora do laboratório.	Firmware e Aplicativo	Entrega 2	Não iniciado
R03	Prevenir	Retirar a senha do <i>config.h</i> , lê-la de <i>secrets.h</i> (fora do Git), gerar senha forte por parede e trocá-la antes de cada demonstração.	Firmware	Próxima demonstração	Não iniciado
R04	Mitigar	Criar a sessão no backend antes do jogo, aceitar o encerramento uma única vez e validar no servidor modo, nível liberado, duração e teto de pontuação.	Backend	Entrega 2	Não iniciado
R05	Mitigar	Vincular a sessão ao cliente pareado, rejeitar trocas durante o treino e limpar o identificador quando esse cliente desconectar.	Firmware	Entrega 2	Não iniciado
R06	Mitigar	Aplicar limitação progressiva por IP e por e-mail em sign-in e sign-up e registrar tentativas falhas sem gravar senhas.	Backend	Entrega 2	Não iniciado
R07	Mitigar	Limitar clientes simultâneos, tamanho de quadro e comandos por segundo, encerrar conexões ociosas e testar a leitura dos sensores sob tráfego anormal.	Firmware	Entrega 2	Não iniciado
R08	Mitigar	Definir lista de origens CORS por ambiente e restringir a interface de escuta e o firewall ao necessário.	Backend	Entrega 2	Não iniciado
R09	Prevenir	Remover o fallback de usuário e senha, exigir <i>DB_PASSWORD</i> fora do ambiente local e usar conta de aplicação com privilégio mínimo.	Backend	Entrega 2	Não iniciado
R10	Mitigar	Reduzir a validade do token de acesso, adotar renovação controlada e permitir revogação por versão de sessão ou identificador jti.	Backend	Entrega 2	Não iniciado
R11	Mitigar	Aplicar correções compatíveis, testar atualizações de versão principal em branch separada e justificar por escrito os alertas não alcançáveis.	Backend e Aplicativo	Entrega 2	Não iniciado
R12	Mitigar	Registrar em logs estruturados autenticação, falhas de validação e abuso, sem senha ou token completo, e revisá-los após testes e demonstrações.	Backend	Entrega 2	Não iniciado

ID	Estratégia	Ações planejadas	Responsável	Prazo	Status
R13	Prevenir	Implementar o MQTT somente com TLS, conta própria por parede, bloqueio de clientes anônimos e ACL restrita ao tópico da parede.	Firmware e Backend	Antes da integração MQTT	Não iniciado
R14	Mitigar	Validar a detecção em etapas (um alvo, dois alvos lado a lado, matriz completa), calibrar o limiar de cada alvo e manter a comparação de picos na janela de 20 ms.	Firmware	Entrega 2	Em andamento
R15	Mitigar	Tratar primeiro os riscos Extremos, dividir as ações por trilha, revisar o andamento semanalmente e cortar escopo secundário antes de adiar respostas de segurança.	Gerente de Projeto	Contínuo	Em andamento
R16	Aceitar (ativo)	Manter relatórios, plano e código versionados no mesmo repositório para adaptação rápida e confirmar por escrito datas e formatos com os professores.	Gerente de Projeto	Contínuo	Em andamento
R17	Mitigar	Usar somente contas fictícias nas demonstrações, coletar o mínimo de dados e limpar a base de teste após cada evento.	Backend e Aplicativo	Próxima demonstração	Não iniciado
R18	Aceitar (ativo)	Manter como contingência o modo simulado do aplicativo e o eco Serial do firmware; avaliar a compra de uma segunda ESP32 como reserva.	Firmware	Contínuo	Em andamento
R19	Prevenir	A parede cria a própria rede (SoftAP) e não depende do Wi-Fi do local. A senha dessa rede é tratada no R03.	Firmware	—	Concluído

Quadro 9 - Localização dos riscos técnicos no código (relativa a src/Entrega1).

ID	Localização no código
R01	<i>frontend/src/config/env.ts:20-24 e backend/src/main.ts:24</i>
R02	<i>backend/firmware/smash_wall/wall_link.cpp:25-50 e frontend/src/device/config.ts:4</i>
R03	<i>backend/firmware/smash_wall/config.h:29-30</i>
R04	<i>backend/src/presentation/http/sessions.controller.ts:18-25 e backend/src/presentation/http/dto/record-session.dto.ts:17-28</i>
R05	<i>backend/firmware/smash_wall/wall_link.cpp:22 e 38-50</i>
R06	<i>backend/src/presentation/http/auth.controller.ts:8-25</i>
R07	<i>backend/firmware/smash_wall/wall_protocol.cpp:65-67</i>
R08	<i>backend/src/main.ts:19 e 24</i>
R09	<i>backend/src/infrastructure/database/database.config.ts:13-17</i>
R10	<i>backend/src/infrastructure/infrastructure.module.ts:65 e backend/.env.example:8</i>
R11	<i>backend/package.json e frontend/package.json</i> (npm audit --omit=dev em 12/09/2026: 9 alertas no backend e 18 moderados no frontend)
R12	Registro apenas no Serial, em <i>backend/firmware/smash_wall/wall_link.cpp:30 e 35</i>
R13	Sem integração MQTT em <i>backend/src</i> nem em <i>backend/firmware/smash_wall</i>
R14	Resposta parcial em <i>backend/firmware/smash_wall/config.h:53-63 e 70</i> (limiar por alvo e janela de pico)
R18	Contingência em <i>frontend/src/device/config.ts:7 e backend/firmware/smash_wall/config.h:92</i>
R19	Resposta implementada em <i>backend/firmware/smash_wall/config.h:19</i>